绿盟科技"远程安全评估系统"安全评估报告

目录

1. 综述信息
   1.1 任务信息
   1.2 网络风险分布
   1.3 风险类别
   1.4 操作系统分布
2. 主机列表
3. 漏洞列表
4. 脆弱账号
5. 参考标准
   5.1 单一漏洞危险等级评定标准
   5.2 主机风险等级评定标准
   5.3 网络风险等级评定标准
   5.4 安全建议

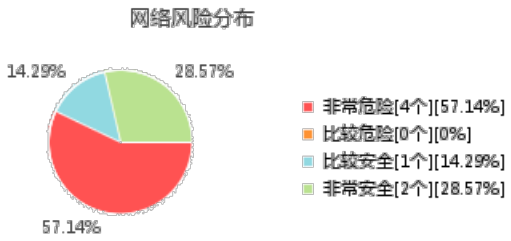
1. 综述信息

1.1 任务信息

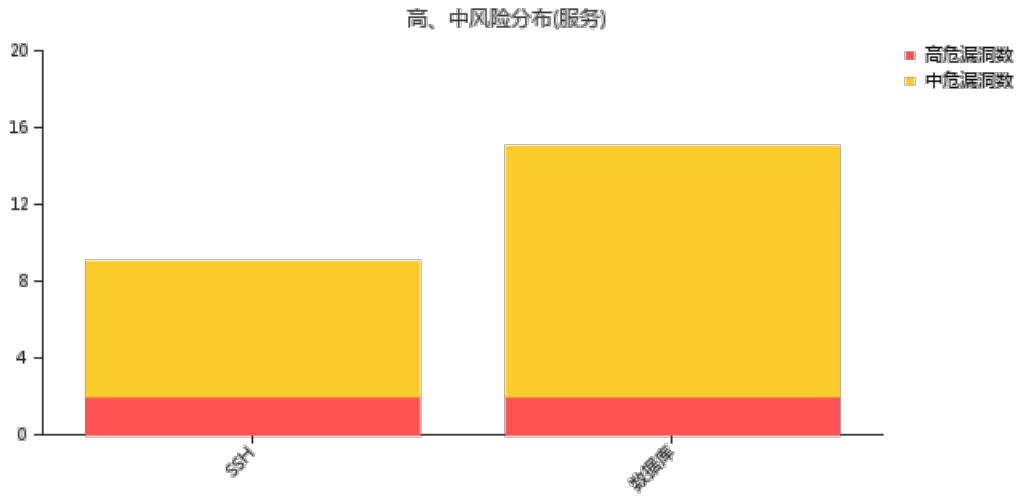
网络风险	风险值:8.7

任务名称	日优化_动设备评估任务
主机统计	已扫描主机数:7 未扫描主机数:0 非常危险主机数:4
时间统计	开始:2017-10-13 12:34:49 结束: 历时:

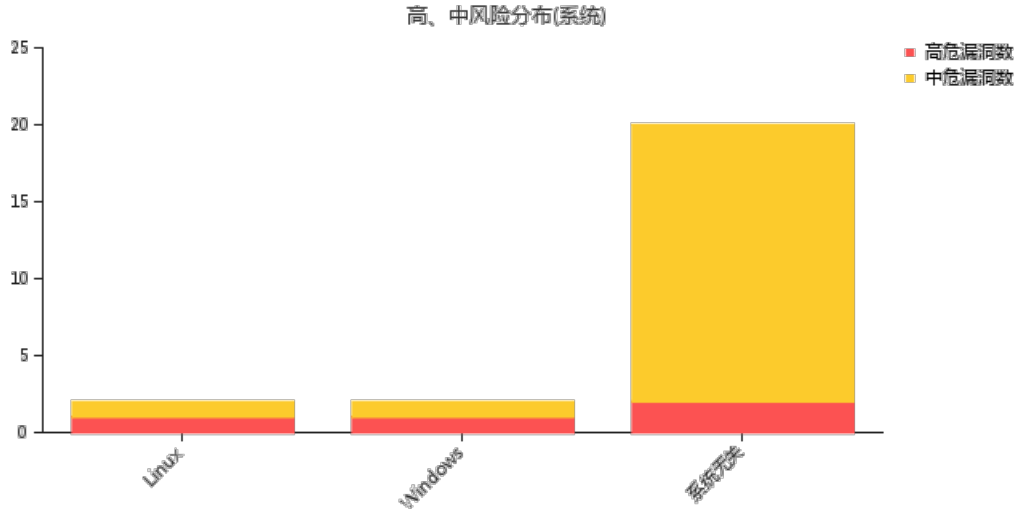
1.2 网络风险分布



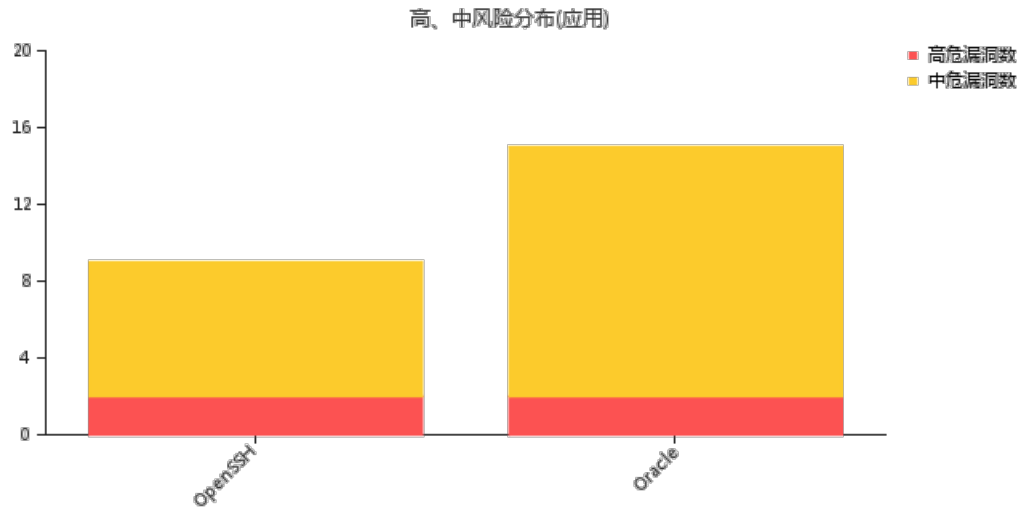
1.3 风险类别



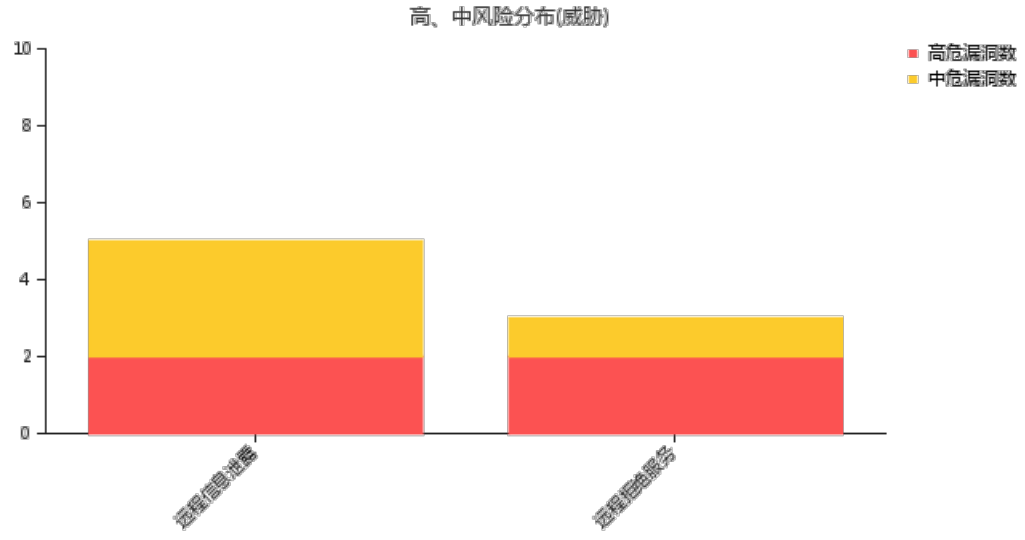
服务				
分类名	高风险	中风险	低风险	总计
SSH	2	7	6	15
WWW	0	0	2	2
其他	0	0	1	1
数据库	2	13	4	19
远程管理	0	0	4	4



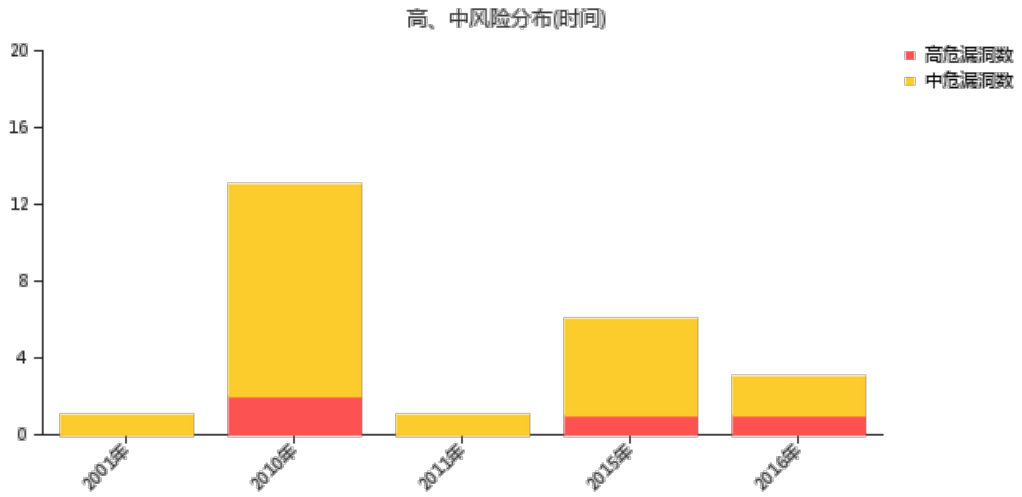
系统				
分类名	高风险	中风险	低风险	总计
Linux	1	1	0	2
Windows	1	1	3	5
系统无关	2	18	14	34



应用				
分类名	高风险	中风险	低风险	总计
OpenSSH	2	7	5	14
Oracle	2	13	4	19
Radmin	0	0	1	1
SSH	0	0	1	1
Terminal Server	0	0	2	2
VNC	0	0	1	1
其他	0	0	3	3



威胁				
分类名	高风险	中风险	低风险	总计
不必要的服务	0	0	3	3
其他	0	16	4	20
远程信息泄露	2	3	8	13
远程拒绝服务	2	1	2	5



时间				
分类名	高风险	中风险	低风险	总计
1999年	0	0	5	5
2001年	0	1	3	4
2008年	0	0	1	1
2010年	2	11	4	17
2011年	0	1	0	1
2015年	1	5	1	7
2016年	1	2	3	6

1.4 操作系统分布

主机数量	操作系统	比率
4	Windows	57.1%
3	Linux	42.9%

2. 主机列表

主机风险等级过滤: 非常危险[4] 比较安全[1] 非常安全[2]

IP地址	主机名	操作系统	高风险	中风险	低风险	风险值
10.112.14.47		Linux	2	7	7	10
10.112.14.46		Linux	2	7	7	10
10.112.14.49		Windows	2	12	13	10
10.112.14.48		Linux	2	7	7	10
10.112.13.31		Windows	0	1	1	2.6
10.112.14.50		Windows	0	0	6	1.6
10.112.12.41		Windows	0	0	2	1.2

3. 漏洞列表

漏洞类别过滤: 高风险[4] 中风险[20] 低风险[17]

漏洞名称	出现次数
OpenSSH 远程权限提升漏洞(CVE-2016-10010)	3

受影响主机	10.112.14.48 10.112.14.46 10.112.14.47
详细描述	OpenSSH 是一组用于安全地访问远程计算机的连接工具。 OpenSSH < 7.4版本禁用特权分离后，sshd服务在实现上存在权限提升漏洞，可使攻击者通过转发Unix域套接字，获取root权限。

	<*来源：Jann Horn *>
解决办法	厂商补丁： OpenSSH ------- 目前厂商已经发布了升级补丁以修复这个安全问题，请到厂商的主页下载： https://www.openssh.com/txt/release-7.4 http://cvsweb.openbsd.org/cgi-bin/cvsweb/src/usr.bin/ssh/serverloop.c.diff?r1=1.188&r2=1.189
威胁分值	9
危险插件	否
发布日期	2016-12-23
CVE编号	CVE-2016-10010
BUGTRAQ	94972
NSFOCUS	35666
CNNVD编号	CNNVD-201612-609
CNCVE编号	CNCVE-201610010
CVSS评分	9
CNVD编号	CNVD-2016-12687

Openssh MaxAuthTries限制绕过漏洞(CVE-2015-5600)	3
受影响主机	10.112.14.48 10.112.14.46 10.112.14.47
详细描述	OpenSSH（OpenBSD Secure Shell）是OpenBSD计划组所维护的一套用于安全访问远程计算机的连接工具。该工具是SSH协议的开源实现，支持对所有的传输进行加密，可有效阻止窃听、连接劫持以及其他网络级的攻击。OpenSSH 6.9及之前版本的sshd中的auth2-chall.c文件中的'kbdint_next_device'函数存在安全漏洞，该漏洞源于程序没有正确限制处理单链接中的keyboard-interactive设备。远程攻击者可借助ssh -oKbdInteractiveDevices选项中较长且重复的列表利用该漏洞实施暴力破解攻击，或造成拒绝服务（CPU消耗）。 <*来源：OpenSSH *>
解决办法	厂商补丁： OpenSSH ------- 目前厂商已经发布了升级补丁以修复这个安全问题，请到厂商的主页下载： http://www.openssh.com/ http://cvsweb.openbsd.org/cgi-bin/cvsweb/src/usr.bin/ssh/auth2-chall.c.diff?r1=1.42&r2=1.43&f=h
威胁分值	8
危险插件	否
发布日期	2015-08-23
CVE编号	CVE-2015-5600
NSFOCUS	30549
CNNVD编号	CNNVD-201508-001
CNCVE编号	CNCVE-20155600
CVSS评分	8.5
CNVD编号	CNVD-2015-05115

Oracle 2010年10月更新修复多个Oracle Database安全漏洞	1
受影响主机	10.112.14.49
详细描述	本次扫描是通过版本进行的，可能发生误报。 Oracle是大型的商业数据库系统。 Oracle数据库的Listene、Net Foundation Layer、OLAP、Application Express、Network Layer、Export组件中存在多个安全漏洞，通过认证的远程用户可以HTTP或Oracle Net协议来利用这些漏洞访问或操控数据库中的某些数据，或导致拒绝服务。 <*来源：Oracle 链接：http://secunia.com/advisories/40594/ http://www.oracle.com/technology/deploy/security/critical-patch-updates/cpujul2010.html

	http://www.us-cert.gov/cas/techalerts/TA10-194B.html *>
解决办法	厂商补丁： Oracle ------ Oracle已经为此发布了一个安全公告（cpuoct2010）以及相应补丁: cpujul2010：Oracle Critical Patch Update Advisory - October2010 链接：http://www.oracle.com/technetwork/topics/security/cpuoct2010-175626.html
威胁分值	7
危险插件	否
发布日期	2010-07-14
CVE编号	CVE-2010-0903
BUGTRAQ	41639
NSFOCUS	15450
CNNVD编号	CNNVD-201007-157
CNCVE编号	CNCVE-20100903
CVSS评分	7.8
CNVD编号	CNVD-2010-1342

Oracle 2010年10月更新修复多个Oracle Database安全漏洞	1
受影响主机	10.112.14.49
详细描述	本次扫描是通过版本进行的，可能发生误报。 Oracle是大型的商业数据库系统。 Oracle数据库的Listene、Net Foundation Layer、OLAP、Application Express、Network Layer、Export组件中存在多个安全漏洞，通过认证的远程用户可以HTTP或Oracle Net协议来利用这些漏洞访问或操控数据库中的某些数据，或导致拒绝服务。 <*来源：Oracle 链接：http://secunia.com/advisories/40594/ http://www.oracle.com/technology/deploy/security/critical-patch-updates/cpujul2010.html http://www.us-cert.gov/cas/techalerts/TA10-194B.html *>
解决办法	厂商补丁： Oracle ------ Oracle已经为此发布了一个安全公告（cpuoct2010）以及相应补丁: cpujul2010：Oracle Critical Patch Update Advisory - October2010 链接：http://www.oracle.com/technetwork/topics/security/cpuoct2010-175626.html
威胁分值	7
危险插件	否
发布日期	2010-07-14
CVE编号	CVE-2010-0911
BUGTRAQ	41639
NSFOCUS	15450
CNNVD编号	CNNVD-201007-165
CNCVE编号	CNCVE-20100911
CVSS评分	7.8
CNVD编号	CNVD-2010-1343

Oracle 2010年4月更新修复多个JavaVM组件安全漏洞(CVE-2010-0866)	1
受影响主机	10.112.14.49
详细描述	本次扫描根据版本进行，可能存在误报。 Oracle是大型的商业数据库系统。 Oracle数据库的JavaVM组件没有正确地限制对DBMS_JVM_EXP_PERMS软件包中调用过程的访问，远程用户可以通过IMPORT_JVM_PERMS过程修改Java策略表；此外DBMS_JAVA.SET_OUTPUT_TO_JAVA过程没有正确地处理某些参数，可能允许用户以SYS权限执行SQL命令。 <*来源：Oracle

	链接：http://secunia.com/advisories/38353/ http://www.oracle.com/technetwork/topics/security/cpuapr2010-099504.html http://www.us-cert.gov/cas/techalerts/TA10-103B.html *>
解决办法	厂商补丁： Oracle ------ Oracle已经为此发布了一个安全公告（cpuapr2010）以及相应补丁： cpuapr2010：Oracle Critical Patch Update Advisory - April 2010 链接：http://www.oracle.com/technetwork/topics/security/cpuapr2010-099504.html
威胁分值	6
危险插件	否
发布日期	2010-04-13
CVE编号	CVE-2010-0866
BUGTRAQ	39424
NSFOCUS	14841
CNNVD编号	CNNVD-201004-204
CNCVE编号	CNCVE-20100866
CVSS评分	6.5
CNVD编号	CNVD-2010-0221

Oracle Database Vault远程安全漏洞	1

受影响主机	10.112.14.49
详细描述	本次扫描是通过版本进行的，可能发生误报。 Oracle Database Vault是一款商业性质的数据库安全产品。 Oracle Database Vault在实现上存在安全漏洞，远程攻击者可通过HTTP协议利用此漏洞获取非授权访问。 <*来源：Oracle *>
解决办法	厂商补丁： Oracle ------ 目前厂商已经发布了升级补丁以修复这个安全问题，请到厂商的主页下载： http://www.oracle.com
威胁分值	6
危险插件	否
发布日期	2011-01-19
CVE编号	CVE-2010-4421
BUGTRAQ	45905
NSFOCUS	16348
CNNVD编号	CNNVD-201101-263
CNCVE编号	CNCVE-20104421
CVSS评分	6.8
CNVD编号	CNVD-2011-0284

Oracle Database Server Cluster Verify Utility本地权限提升漏洞	1

受影响主机	10.112.14.49
详细描述	本次扫描是通过版本进行的，可能发生误报。 运行于Windows平台上的Oracle Database Server 10.2.0.4，10.2.0.5，11.1.0.7，和11.2.0.1版本中的Cluster Verify Utility组件中存在未明漏洞。本地用户可以借助未知向量影响机密性、完整性和可用性。
解决办法	厂商补丁： Oracle ------ 目前厂商已经发布了升级补丁以修复此安全问题，补丁获取链接： http://www.oracle.com/technetwork/topics/security/cpujan2011-194091.html
威胁分值	6

危险插件	否
发布日期	2011-01-19
CVE编号	CVE-2010-4423
CNNVD编号	CNNVD-201101-262
CNCVE编号	CNCVE-20104423
CVSS评分	6.9
CNVD编号	CNVD-2011-0285

Oracle数据库Java存储过程竞争条件代码执行漏洞	1

受影响主机	10.112.14.49
详细描述	本次扫描是通过版本进行的，可能发生误报。 Oracle是大型的商业数据库系统。 Oracle的自定义SecurityManager实现依赖于特殊对象的标签来判断特权调用是否成功。由于一个竞争条件，通过认证的用户可以绕过沙盒限制执行Java代码。 <*来源：Sami Koivu 链接：http://secunia.com/advisories/41815/ http://marc.info/?l=full-disclosure&m=128692160118293&q=p3 http://www.us-cert.gov/cas/techalerts/TA10-287A.html http://www.oracle.com/technetwork/topics/security/cpuoct2010-175626.html *>
解决办法	厂商补丁： Oracle ------ Oracle已经为此发布了一个安全公告（cpuoct2010）以及相应补丁： cpuoct2010：Oracle Critical Patch Update Advisory - October 2010 链接：http://www.oracle.com/technetwork/topics/security/cpuoct2010-175626.html
威胁分值	6
危险插件	否
发布日期	2010-10-13
CVE编号	CVE-2010-2419
BUGTRAQ	43935
NSFOCUS	15922
CNNVD编号	CNNVD-201010-156
CNCVE编号	CNCVE-20102419
CVSS评分	6.5
CNVD编号	CNVD-2010-2303

Oracle 2010年10月更新修复多个Oracle Database安全漏洞	1

受影响主机	10.112.14.49
详细描述	本次扫描是通过版本进行的，可能发生误报。 Oracle是大型的商业数据库系统。 Oracle数据库的Listene、Net Foundation Layer、OLAP、Application Express、Network Layer、Export组件中存在多个安全漏洞，通过认证的远程用户可以HTTP或Oracle Net协议来利用这些漏洞访问或操控数据库中的某些数据，或导致拒绝服务。 <*来源：Oracle 链接：http://secunia.com/advisories/40594/ http://www.oracle.com/technology/deploy/security/critical-patch-updates/cpujul2010.html http://www.us-cert.gov/cas/techalerts/TA10-194B.html *>
解决办法	厂商补丁： Oracle ------ Oracle已经为此发布了一个安全公告（cpuoct2010）以及相应补丁： cpujul2010：Oracle Critical Patch Update Advisory - October2010 链接：http://www.oracle.com/technetwork/topics/security/cpuoct2010-175626.html
威胁分值	6
危险插件	否

发布日期	2010-07-14
CVE编号	CVE-2010-0902
BUGTRAQ	41633
NSFOCUS	15450
CNNVD编号	CNNVD-201007-156
CNCVE编号	CNCVE-20100902
CVSS评分	6
CNVD编号	CNVD-2010-1341

OpenSSH sshd mm_answer_pam_free_ctx释放后重利用漏洞(CVE-2015-6564)	3

受影响主机	10.112.14.48 10.112.14.46 10.112.14.47
详细描述	OpenSSH是SSH协议的开源实现。 非OpenBSD平台上OpenSSH 7.0之前版本，sshd内monitor.c的mm_answer_pam_free_ctx函数存在释放后重利用漏洞，这可使本地用户利用sshd uid控制，发送构造的MONITOR_REQ_PAM_FREE_CTX请求，获取提升的权限。 <*来源：OpenSSH *>
解决办法	厂商补丁： OpenSSH ------- 目前厂商已经发布了升级补丁以修复这个安全问题，请到厂商的主页下载： http://www.openssh.com/txt/release-7.0 https://github.com/openssh/openssh-portable/commit/d4697fe9a28dab7255c60433e4dd23cf7fce8a8b http://seclists.org/fulldisclosure/2015/Aug/54
威胁分值	6
危险插件	否
发布日期	2015-08-23
CVE编号	CVE-2015-6564
NSFOCUS	31294
CNNVD编号	CNNVD-201508-505
CNCVE编号	CNCVE-20156564
CVSS评分	6.9
CNVD编号	CNVD-2015-05760

Oracle TNS Listener SID 可以被猜测	1

受影响主机	10.112.13.31
详细描述	可以通过暴力猜测的方法探测出Oracle TNS Listener SID。探测出的SID可以用于进一步探测Oracle 数据库的口令
解决办法	1. 不应该使用安装Oracle时默认的SID(ORCL)，应该设置复杂度较高的SID。 2. 对于短时间内难以通过第1种方式修补漏洞的情况，应考虑加强主机和网络层面的访问控制策略。例如采用白名单的方式，仅允许授权主机IP访问该端口，避免漏洞被攻击者恶意利用。
威胁分值	5
危险插件	否
发布日期	2001-01-01

OpenSSH do_setup_env函数权限提升漏洞(CVE-2015-8325)	3

受影响主机	10.112.14.48 10.112.14.46 10.112.14.47
详细描述	OpenSSH是SSH协议的开源实现。 OpenSSH 7.2p2之前版本, sshd/ session.c/ do_setup_env函数存在安全漏洞, 启用了UseLogin功能且PAM配置为读取用户主目录内的 .pam_environment文件后, 本地用户通过触发/bin/login程序构造的环境, 可提升其权限。
解决办法	厂商补丁: OpenSSH ------- 目前厂商已经发布了升级补丁以修复这个安全问题，请到厂商的主页下载： http://www.openssh.com/

	https://people.canonical.com/~ubuntu-security/cve/2015/CVE-2015-8325.html https://people.canonical.com/~ubuntu-security/cve/2015/CVE-2015-8325.html https://security-tracker.debian.org/tracker/CVE-2015-8325 https://anongit.mindrot.org/openssh.git/commit/? id=85bdcd7c92fe7ff133bbc4e10a65c91810f88755
威胁分值	5
危险插件	否
发布日期	2016-05-04
CVE编号	CVE-2015-8325
NSFOCUS	33302
CNNVD编号	CNNVD-201604-341
CNCVE编号	CNCVE-20158325
CVSS评分	5
CNVD编号	CNVD-2016-02373

OpenSSH auth_password函数拒绝服务漏洞(CVE-2016-6515)	3
受影响主机	10.112.14.48 10.112.14.46 10.112.14.47
详细描述	OpenSSH是SSH协议的开源实现。 OpenSSH 7.3之前版本，sshd/auth-passwd.c/auth_password函数未限制密码验证中的密码长度，远程攻击者通过较长的字符串，利用此漏洞可造成拒绝服务。
解决办法	厂商补丁: OpenSSH ------- 目前厂商已经发布了升级补丁以修复这个安全问题，请到厂商的主页下载: http://openwall.com/lists/oss-security/2016/08/01/2 https://github.com/openssh/openssh-portable/commit/fcd135c9df440bcd2d5870405ad3311743d78d97
威胁分值	5
危险插件	否
发布日期	2016-08-08
CVE编号	CVE-2016-6515
NSFOCUS	34504
CNNVD编号	CNNVD-201608-172
CNCVE编号	CNCVE-20166515
CVSS评分	5
CNVD编号	CNVD-2016-06210

OpenSSH <=7.2p1 xauth命令注入漏洞(CVE-2016-3115)	3
受影响主机	10.112.14.48 10.112.14.46 10.112.14.47
详细描述	OpenSSH是SSH协议的开源实现。 OpenSSH <=7.2p1在实现上存在xauth命令注入漏洞，可导致绕过forced-command及/bin/false。 <*来源：tintinweb *>
解决办法	厂商补丁: OpenSSH ------- 目前厂商已经发布了升级补丁以修复这个安全问题，请到厂商的主页下载: [1] http://www.openssh.com/ [2] https://github.com/openssh/openssh-portable/blob/5a0fcb77287342e2fc2ba1cee79b6af108973dc2/session.c#L1388 [3] https://github.com/openssh/openssh-portable/blob/19bcf2ea2d17413f2d9730dd2a19575ff86b9b6a/clientloop.c#L376 [4] http://linux.die.net/man/1/xauth [5] http://www.openssh.com/txt/x11fwd.adv
威胁分值	5

危险插件	否
发布日期	2015-08-04
CVE编号	CVE-2016-3115
NSFOCUS	32682
CNNVD编号	CNNVD-201603-244
CNCVE编号	CNCVE-20163115
CVSS评分	5.5
CNVD编号	CNVD-2016-01769

OpenSSH 远程代码执行漏洞(CVE-2016-10009)	3
受影响主机	10.112.14.48 10.112.14.46 10.112.14.47
详细描述	OpenSSH 是一组用于安全地访问远程计算机的连接工具。 OpenSSH < 7.4版本ssh-agent未对加载的 PKCS#11 模块进行验证，在实现上存在任意执行代码漏洞。可使攻击者在受影响应用上下文中执行任意代码。 <*来源：Jann Horn *>
解决办法	厂商补丁： OpenSSH ------- 目前厂商已经发布了升级补丁以修复这个安全问题，请到厂商的主页下载： https://www.openssh.com/txt/release-7.4 http://cvsweb.openbsd.org/cgi-bin/cvsweb/src/usr.bin/ssh/ssh-agent.c.diff?r1=1.214&r2=1.215
威胁分值	5
危险插件	否
发布日期	2016-12-23
CVE编号	CVE-2016-10009
BUGTRAQ	94968
NSFOCUS	35665
CNNVD编号	CNNVD-201612-616
CNCVE编号	CNCVE-201610009
CVSS评分	5.0
CNVD编号	CNVD-2016-12688

Oracle 2010年4月更新修复多个JavaVM组件安全漏洞(CVE-2010-0867)	1
受影响主机	10.112.14.49
详细描述	本次扫描根据版本进行，可能存在误报。 Oracle是大型的商业数据库系统。 Oracle数据库的JavaVM组件没有正确地限制对DBMS_JVM_EXP_PERMS软件包中调用过程的访问，远程用户可以通过IMPORT_JVM_PERMS过程修改Java策略表；此外DBMS_JAVA.SET_OUTPUT_TO_JAVA过程没有正确地处理某些参数，可能允许用户以SYS权限执行SQL命令。 <*来源：Oracle 链接：http://secunia.com/advisories/38353/ http://www.oracle.com/technetwork/topics/security/cpuapr2010-099504.html http://www.us-cert.gov/cas/techalerts/TA10-103B.html *>
解决办法	厂商补丁： Oracle ------ Oracle已经为此发布了一个安全公告（cpuapr2010）以及相应补丁： cpuapr2010：Oracle Critical Patch Update Advisory - April 2010 链接：http://www.oracle.com/technetwork/topics/security/cpuapr2010-099504.html
威胁分值	4
危险插件	否
发布日期	2010-04-13

CVE编号	CVE-2010-0867
NSFOCUS	14841
CNNVD编号	CNNVD-201004-205
CNCVE编号	CNCVE-20100867
CVSS评分	4.0
CNVD编号	CNVD-2010-0629

Oracle Database Server Scheduler Agent远程安全漏洞	1
受影响主机	10.112.14.49
详细描述	本次扫描是通过版本进行的，可能发生误报。 Oracle Database Server是数据库服务器。 Oracle Database Server的Scheduler Agent在实现上存在安全漏洞，远程已认证的攻击者可以利用此漏洞实现对系统非授权访问。 <*来源：Oracle *>
解决办法	厂商补丁： Oracle ------ 目前厂商已经发布了升级补丁以修复这个安全问题，请到厂商的主页下载： http://www.oracle.com/technetwork/topics/security/cpujan2011-194091.html
威胁分值	4
危险插件	否
发布日期	2011-01-19
CVE编号	CVE-2010-4413
BUGTRAQ	45845
NSFOCUS	16335
CNNVD编号	CNNVD-201101-271
CNCVE编号	CNCVE-20104413
CVSS评分	4.3
CNVD编号	CNVD-2011-0282

Oracle Spatial UI Infrastructure组件远程安全漏洞	1
受影响主机	10.112.14.49
详细描述	本次扫描是通过版本进行的，可能发生误报。 Oracle spatial是一套空间数据处理系统，是Oracle数据库强大的核心特性，包含了用于存储矢量数据类型、栅格数据类型和持续拓扑数据的原生数据类型。 Oracle spatial的UI Infrastructure组件在实现上存在安全漏洞，远程攻击者可通过Oracle Net协议利用此漏洞。 <*来源：Oracle *>
解决办法	厂商补丁： Oracle ------ 目前厂商已经发布了升级补丁以修复这个安全问题，请到厂商的主页下载： http://www.oracle.com/technetwork/topics/security/cpujan2011-194091.html
威胁分值	4
危险插件	否
发布日期	2011-01-19
CVE编号	CVE-2010-3590
BUGTRAQ	45880
NSFOCUS	16347
CNNVD编号	CNNVD-201101-280

CNCVE编号	CNCVE-20103590
CVSS评分	4.9
CNVD编号	CNVD-2011-0280

Oracle Database Server Job Queue组件安全漏洞	1
受影响主机	10.112.14.49
详细描述	本次扫描是通过版本进行的，可能发生误报。 Oracle Database Server 11.2.0.1，11.1.0.7，10.2.0.3，10.2.0.4和10.1.0.5版本中的Job Queue组件中存在未明漏洞。远程认证用户可以利用此漏洞影响保密性，完整性和可用性。该漏洞与SYS.DBMS_IJOB相关。
解决办法	厂商补丁： Oracle ------ http://www.oracle.com/technetwork/topics/security/cpuoct2010-175626.html
威胁分值	4
危险插件	否
发布日期	2010-10-13
CVE编号	CVE-2010-2411
CNNVD编号	CNNVD-201010-164
CNCVE编号	CNCVE-20102411
CVSS评分	4.6
CNVD编号	CNVD-2010-2297

Oracle数据库CREATE_CHANGE_SET过程SQL注入漏洞	1
受影响主机	10.112.14.49
详细描述	本次扫描是通过版本进行的，可能发生误报。 Oracle是大型的商业数据库系统。 Oracle数据库的Change Data Capture组件中提供了一个DBMS_CDC_PUBLISH PL/SQL软件包，该软件包的CREATE_CHANGE_SET过程中存在SQL注入漏洞。恶意用户可以以特殊参数调用有漏洞的过程，导致以SYS用户的权限执行SQL语句。 利用这个漏洞要求拥有对SYS.DBMS_CDC_PUBLISH软件包的EXECUTE权限。默认下给予了EXECUTE_CATALOG_ROLE角色的用户拥有这个权限。 <*来源：Esteban Martínez Fayó （secemf@gmail.com） 链接：http://secunia.com/advisories/41815/ http://marc.info/?l=full-disclosure&m=128708541022160&w=2 http://www.us-cert.gov/cas/techalerts/TA10-287A.html http://www.oracle.com/technetwork/topics/security/cpuoct2010-175626.html *>
解决办法	厂商补丁： Oracle ------ Oracle已经为此发布了一个安全公告（cpuoct2010）以及相应补丁： cpuoct2010：Oracle Critical Patch Update Advisory - October 2010 链接：http://www.oracle.com/technetwork/topics/security/cpuoct2010-175626.html
威胁分值	4
危险插件	否
发布日期	2010-10-13
CVE编号	CVE-2010-2415
BUGTRAQ	43956
NSFOCUS	15911
CNNVD编号	CNNVD-201010-160
CNCVE编号	CNCVE-20102415
CVSS评分	4.9
CNVD编号	CNVD-2010-2302

Oracle Database Server和Fusion Middleware Help组件未明漏洞	1
受影响主机	10.112.14.49
详细描述	Oracle Server是一个对象一关系数据库管理系统。它提供开放的、全面的、和集成的信息管理方法。每个Server

	由一个 Oracle DB和一个 Oracle Server实例组成。它具有场地自治性(Site Autonomy)和提供数据存储透明机制，以此可实现数据存储透明性。Oracle Fusion Middleware 是Oracle的中间件解决方案组合，它不仅包含众多中间件功能，而且还有一套广泛的软件集合，用于协助开发、部署及管理SOA和其它应用程序。 Oracle Database Server和Oracle Fusion Middleware的Oracle Help组件中存在未明漏洞。远程攻击者可以借助未知向量影响完整性。
解决办法	目前厂商已经发布了升级补丁以修复此安全问题，补丁获取链接： http://www.oracle.com/technetwork/topics/security/cpuapr2011-301950.html
威胁分值	4
危险插件	否
发布日期	2011-04-19
CVE编号	CVE-2011-0785
CNNVD编号	CNNVD-201104-194
CNCVE编号	CNCVE-20110785
CVSS评分	4.3
CNVD编号	CNVD-2011-1539

Oracle 2010年4月更新修复多个JavaVM组件安全漏洞	1
受影响主机	10.112.14.49
详细描述	Oracle是大型的商业数据库系统。 Oracle数据库的JavaVM组件没有正确地限制对DBMS_JVM_EXP_PERMS软件包中调用过程的访问，远程用户可以通过IMPORT_JVM_PERMS过程修改Java策略表；此外DBMS_JAVA.SET_OUTPUT_TO_JAVA过程没有正确地处理某些参数，可能允许用户以SYS权限执行SQL命令。
解决办法	Oracle ------ Oracle已经为此发布了一个安全公告（cpuapr2010）以及相应补丁： cpuapr2010：Oracle Critical Patch Update Advisory - April 2010 链接：http://www.oracle.com/technetwork/topics/security/cpuapr2010-099504.html
威胁分值	4
危险插件	否
发布日期	2010-03-27
CVE编号	CVE-2010-0867
BUGTRAQ	39427
NSFOCUS	14841
CNNVD编号	CNNVD-201004-205
CNCVE编号	CNCVE-20100867
CVSS评分	4
CNVD编号	CNVD-2010-0629

OpenSSH 'x11_open_helper()'函数安全限制绕过漏洞(CVE-2015-5352)	3
受影响主机	10.112.14.48 10.112.14.46 10.112.14.47
详细描述	OpenSSH是SSH (Secure SHell)协议的免费开源实现。SSH协议族可以用来进行远程控制，或在计算机之间传送文件。 OpenSSH 6.9之前版本，使用非ForwardX11Trusted模式时，ssh channels.c内的函数x11_open_helper没有检查X连接的拒绝截止日期，这可使远程攻击者通过允许时间窗口外的连接，利用此漏洞绕过目标访问限制。
解决办法	厂商补丁: OpenSSH ------- 目前厂商已经发布了升级补丁以修复这个安全问题，请到厂商的主页下载： https://anongit.mindrot.org/openssh.git/commit/?h=V_6_9&id=1bf477d3cdf1a864646d59820878783d42357a1d http://www.openssh.com/txt/release-6.9
威胁分值	4
危险插件	否
发布日期	2015-08-04
CVE编号	CVE-2015-5352

BUGTRAQ	75525
NSFOCUS	30551
CNNVD编号	CNNVD-201507-218
CNCVE编号	CNCVE-20155352
CVSS评分	4.3
CNVD编号	CNVD-2015-04413

OpenSSH 安全漏洞(CVE-2016-1908)	3
受影响主机	10.112.14.48 10.112.14.46 10.112.14.47
详细描述	OpenSSH（OpenBSD Secure Shell）是OpenBSD计划组所维护的一套用于安全访问远程计算机的连接工具。该工具是SSH协议的开源实现，支持对所有的传输进行加密，可有效阻止窃听、连接劫持以及其他网络级的攻击。OpenSSH中存在安全漏洞，该漏洞源于OpenSSH客户端没有正确为不可信的X11转发生成身份验证cookie。攻击者可利用该漏洞与本地X服务器建立可信连接。
解决办法	厂商补丁： OpenSSH ------- 目前厂商已经发布了升级补丁以修复这个安全问题，请到厂商的主页下载： [1] http://www.openssh.com/ [2] http://www.openssh.com/txt/release-7.2
威胁分值	4
危险插件	否
发布日期	2015-08-04
CVE编号	CVE-2016-1908
BUGTRAQ	84427
NSFOCUS	36354
CNNVD编号	CNNVD-201603-248
CNCVE编号	CNCVE-20161908
CVSS评分	4
CNVD编号	CNVD-2016-01730

Oracle Database Server Database Vault本地信息泄露漏洞	1
受影响主机	10.112.14.49
详细描述	本次扫描是通过版本进行的，可能发生误报。 Oracle Database Vault是一款商业性质的数据库安全产品。 Oracle Database Vault在实现上存在安全漏洞，本地攻击者可利用此漏洞获取受影响应用程序管理员的会话ID。 <*来源：Oracle *>
解决办法	厂商补丁： Oracle ------ 目前厂商已经发布了升级补丁以修复这个安全问题，请到厂商的主页下载： http://www.oracle.com/technetwork/topics/security/cpujan2011-194091.html
威胁分值	3
危险插件	否
发布日期	2011-01-19
CVE编号	CVE-2010-4420
BUGTRAQ	45855
NSFOCUS	16367
CNNVD编号	CNNVD-201101-264
CNCVE编号	CNCVE-20104420
CVSS评分	3.6

CNVD编号	CNVD-2011-0283

OpenSSH 本地信息泄露漏洞(CVE-2016-10011)	3
受影响主机	10.112.14.48 10.112.14.46 10.112.14.47
详细描述	OpenSSH 是一组用于安全地访问远程计算机的连接工具。 OpenSSH < 7.4版本在sshd服务实现上存在信息泄露漏洞，可通过realloc()将主机密钥泄露到特权分离的子进程。 <*来源：Jann Horn *>
解决办法	厂商补丁： OpenSSH ------- 目前厂商已经发布了升级补丁以修复这个安全问题，请到厂商的主页下载： https://www.openssh.com/txt/release-7.4 http://cvsweb.openbsd.org/cgi-bin/cvsweb/src/usr.bin/ssh/authfile.c.diff?r1=1.121&r2=1.122
威胁分值	3
危险插件	否
发布日期	2016-12-23
CVE编号	CVE-2016-10011
BUGTRAQ	94977
NSFOCUS	35667
CNNVD编号	CNNVD-201612-606
CNCVE编号	CNCVE-201610011
CVSS评分	3
CNVD编号	CNVD-2016-12686

OpenSSH 安全限制绕过漏洞(CVE-2016-10012)	3
受影响主机	10.112.14.48 10.112.14.46 10.112.14.47
详细描述	OpenSSH 是一组用于安全地访问远程计算机的连接工具。 OpenSSH < 7.4版本sshd服务在共享内存管理器边界检查实现上存在安全限制绕过漏洞，可使攻击者针对沙盒特权分离进程的特权监控进程执行安全攻击，获取提升的权限。 <*来源：Guido Vranken *>
解决办法	厂商补丁： OpenSSH ------- 目前厂商已经发布了升级补丁以修复这个安全问题，请到厂商的主页下载： https://www.openssh.com/txt/release-7.4 http://cvsweb.openbsd.org/cgi-bin/cvsweb/src/usr.bin/ssh/monitor.c.diff?r1=1.165&r2=1.166 http://cvsweb.openbsd.org/cgi-bin/cvsweb/src/usr.bin/ssh/monitor.h.diff?r1=1.19&r2=1.20
威胁分值	3
危险插件	否
发布日期	2016-12-23
CVE编号	CVE-2016-10012
BUGTRAQ	94975
NSFOCUS	35668
CNNVD编号	CNNVD-201612-618
CNCVE编号	CNCVE-201610012
CVSS评分	3
CNVD编号	CNVD-2016-12684

Oracle 2010年10月更新修复多个Oracle Database安全漏洞	1
受影响主机	10.112.14.49
详细描述	本次扫描是通过版本进行的，可能发生误报。 Oracle是大型的商业数据库系统。

	Oracle数据库的Listene、Net Foundation Layer、OLAP、Application Express、Network Layer、Export组件中存在多个安全漏洞，通过认证的远程用户可以HTTP或Oracle Net协议来利用这些漏洞访问或操控数据库中的某些数据，或导致拒绝服务。 <*来源：Oracle 链接：http://secunia.com/advisories/40594/ http://www.oracle.com/technology/deploy/security/critical-patch-updates/cpujul2010.html http://www.us-cert.gov/cas/techalerts/TA10-194B.html *>
解决办法	厂商补丁： Oracle ------ Oracle已经为此发布了一个安全公告（cpuoct2010）以及相应补丁: cpujul2010：Oracle Critical Patch Update Advisory - October2010 链接：http://www.oracle.com/technetwork/topics/security/cpuoct2010-175626.html
威胁分值	2
危险插件	否
发布日期	2010-07-14
CVE编号	CVE-2010-0900
BUGTRAQ	41632
NSFOCUS	15450
CNCVE编号	CNCVE-20100900
CVSS评分	2.6
CNVD编号	CNVD-2010-1339

Oracle 2010年10月更新修复多个Oracle Database安全漏洞	1

受影响主机	10.112.14.49
详细描述	本次扫描是通过版本进行的，可能发生误报。 Oracle是大型的商业数据库系统。 Oracle数据库的Listene、Net Foundation Layer、OLAP、Application Express、Network Layer、Export组件中存在多个安全漏洞，通过认证的远程用户可以HTTP或Oracle Net协议来利用这些漏洞访问或操控数据库中的某些数据，或导致拒绝服务。 <*来源：Oracle 链接：http://secunia.com/advisories/40594/ http://www.oracle.com/technology/deploy/security/critical-patch-updates/cpujul2010.html http://www.us-cert.gov/cas/techalerts/TA10-194B.html *>
解决办法	厂商补丁： Oracle ------ Oracle已经为此发布了一个安全公告（cpuoct2010）以及相应补丁: cpujul2010：Oracle Critical Patch Update Advisory - October2010 链接：http://www.oracle.com/technetwork/topics/security/cpuoct2010-175626.html
威胁分值	2
危险插件	否
发布日期	2010-07-14
CVE编号	CVE-2010-0901
BUGTRAQ	41635
NSFOCUS	15450
CNNVD编号	CNNVD-201007-155
CNCVE编号	CNCVE-20100901
CVSS评分	2.1
CNVD编号	CNVD-2010-1340

OpenSSH CBC模式信息泄露漏洞(CVE-2008-5161)【原理扫描】	3

受影响主机	10.112.14.48 10.112.14.46 10.112.14.47
详细描述	OpenSSH是一种开放源码的SSH协议的实现，初始版本用于OpenBSD平台，现在已经被移植到多种Unix/Linux

	类操作系统下。 如果配置为CBC模式的话，OpenSSH没有正确地处理分组密码算法加密的SSH会话中所出现的错误，导致可能泄露密文中任意块最多32位纯文本。在以标准配置使用OpenSSH时，攻击者恢复32位纯文本的成功概率为2^{-18}，此外另一种攻击变种恢复14位纯文本的成功概率为2^{-14}。
解决办法	临时解决方法： * 在SSH会话中仅使用CTR模式加密算法，如AES-CTR。 厂商补丁： OpenSSH ------- 目前厂商已经发布了升级补丁以修复这个安全问题，请到厂商的主页下载： https://downloads.ssh.com/ 对于具体Linux发行版中使用的版本，可以参考如下链接，确认系统是否受该漏洞影响： Redhat ------- https://rhn.redhat.com/errata/RHSA-2009-1287.html Suse ------- http://support.novell.com/security/cve/CVE-2008-5161.html Ubuntu ------- http://people.canonical.com/~ubuntu-security/cve/2008/CVE-2008-5161.html
威胁分值	2
危险插件	否
发布日期	2008-11-19
CVE编号	CVE-2008-5161
BUGTRAQ	32319
NSFOCUS	12630
CNNVD编号	CNNVD-200811-321
CNCVE编号	CNCVE-20085161
CVSS评分	2.6
CNVD编号	CNVD-2009-12630

嵌入式web服务器探测	1
受影响主机	10.112.14.49
详细描述	远端主机运行着嵌入式web服务器
解决办法	请确定使用此服务符合您的安全规范。 如果不需要次服务，建议关闭。
威胁分值	1
危险插件	否
发布日期	2001-01-01

Oracle Database Server Perl组件未明漏洞	1
受影响主机	10.112.14.49
详细描述	Perl是一种高级、通用、直译式、动态的程序语言。 Oracle Database Server 11.2.0.1，11.1.0.7，10.2.0.3，10.2.0.4和10.1.0.5;Fusion Middleware 11.1.1.1.0和11.1.1.2.0版本中的Perl组件中存在未明漏洞。本地用户可以借助与Local Logon有关未知向量影响完整性。
解决办法	目前厂商已经发布了升级补丁以修复此安全问题，补丁获取链接： http://www.oracle.com/technetwork/topics/security/cpuoct2010-175626.html
威胁分值	1
危险插件	否
发布日期	2010-10-13
CVE编号	CVE-2010-2389
CNNVD编号	CNNVD-201010-176
CNCVE编号	CNCVE-20102389

CVSS评分	1.0
CNVD编号	CNVD-2010-2286

检测到目标主机上运行着Windows终端服务	2
受影响主机	10.112.14.49 10.112.14.50
详细描述	扫描过程中检测到目标主机上运行着Windows终端服务。该服务允许Windows用户远程登录并获取图形操作界面。如果攻击者拥有有效登录帐号及口令，就可能通过该服务获取更多控制权。
解决办法	如果您并不真实需要Windows终端服务，请禁用该服务。
威胁分值	1
危险插件	否
发布日期	2001-01-01

Windows终端服务器通信加密级别检查	2
受影响主机	10.112.14.49 10.112.14.50
详细描述	Microsoft Windows远程桌面协议用于连接Windows终端服务。RDP是客户端和服务端之间的通信协议。 终端服务器和客户端通信采用RC4算法加密，在如下选项： 管理工具->终端服务器配置->rdp-tcp->常规选项卡->加密级别 设置为中或客户端兼容或低时，允许使用或只能使用40或56位的密钥加密通信数据，40或56位密钥对于保护机密数据是远远不够的。如果您的当前终端服务器支持128位加密密钥，将该选项设置为高将强制使用128密钥加密通信数据。
解决办法	按如下步骤进行操作： 管理工具->终端服务器配置->rdp-tcp->常规选项卡->加密级别 将该选项设置为"高"。 注意，该设置将使得强制使用128位RC4加密通信数据，不支持128位加密的老客户端可能无法连接服务器。
威胁分值	1
危险插件	否
发布日期	2001-01-01

远端VNC服务正在运行	2
受影响主机	10.112.14.49 10.112.14.50
详细描述	远程主机上正在运行VNC服务。 VNC服务允许用户对远程主机进行管理，这可能成为攻击者入侵的一个入口。
解决办法	NSFOCUS建议您采取以下措施以降低威胁： * 如果您不需要该服务您应该禁止VNC。
威胁分值	1
危险插件	否
发布日期	1999-01-01
CVE编号	CVE-1999-0660

远程VNC HTTP服务正在运行	2
受影响主机	10.112.14.49 10.112.14.50
详细描述	远程主机运行了VNC HTTP服务，该服务允许终端通过HTTP协议被远程显示。
解决办法	NSFOCUS建议您采取以下措施以降低威胁： * 在您的防火墙上限制对端口TCP 5800/5801/5802的访问； * 如果你不需要该服务，请关掉它。
威胁分值	1
危险插件	否
发布日期	1999-01-01
CVE编号	CVE-1999-0660

可通过HTTP获取远端WWW服务信息	5
受影响主机	10.112.12.41 10.112.14.49 10.112.14.50
详细描述	本插件检测远端HTTP Server信息。这可能使得攻击者了解远程系统类型以便进行下一步的攻击。

解决办法	NSFOCUS建议您采取以下措施以降低威胁： * 改变您的HTTP服务器的缺省banner。
威胁分值	1
危险插件	否
发布日期	1999-01-01
CVE编号	CVE-1999-0633

SSH版本信息可被获取	3
受影响主机	10.112.14.48 10.112.14.46 10.112.14.47
详细描述	SSH服务允许远程攻击者获得ssh的具体信息，如版本号等等。这可能为攻击者发动进一步攻击提供帮助。
解决办法	NSFOCUS建议您采取以下措施以降低威胁： * 修改源代码或者配置文件改变SSH服务的缺省banner。
威胁分值	1
危险插件	否
发布日期	1999-01-01
CVE编号	CVE-1999-0634

OpenSSH sshd monitor组件欺骗漏洞(CVE-2015-6563)	3
受影响主机	10.112.14.48 10.112.14.46 10.112.14.47
详细描述	OpenSSH是SSH协议的开源实现。 非OpenBSD平台上OpenSSH 7.0之前版本，sshd内monitor组件接受 MONITOR_REQ_PAM_INIT_CTX请求内无关的用户名数据，这可使本地用户利用ssh登陆访问及sshd uid控制，发送构造的MONITOR_REQ_PWNAM请求，执行模拟攻击。
解决办法	厂商补丁: OpenSSH ------- 目前厂商已经发布了升级补丁以修复这个安全问题，请到厂商的主页下载: http://www.openssh.com/txt/release-7.0 https://github.com/openssh/openssh-portable/commit/d4697fe9a28dab7255c60433e4dd23cf7fce8a8b http://seclists.org/fulldisclosure/2015/Aug/54
威胁分值	1
危险插件	否
发布日期	2015-10-23
CVE编号	CVE-2015-6563
NSFOCUS	31170
CNNVD编号	CNNVD-201508-504
CNCVE编号	CNCVE-20156563
CVSS评分	1.9
CNVD编号	CNVD-2015-05761

允许Traceroute探测	7
受影响主机	10.112.12.41 10.112.13.31 10.112.14.48 10.112.14.49 10.112.14.50 10.112.14.46 10.112.14.47
详细描述	本插件使用Traceroute探测来获取扫描器与远程主机之间的路由信息。攻击者也可以利用这些信息来了解目标网络的网络拓扑。
威胁分值	1
危险插件	否
发布日期	1999-01-01

探测到SSH服务器支持的算法	3
受影响主机	10.112.14.48 10.112.14.46 10.112.14.47
详细描述	本插件用来获取SSH服务器支持的算法列表
威胁分值	0
危险插件	否
发布日期	2016-03-08

4. 脆弱账号

无数据

5. 参考标准

5.1 单一漏洞危险等级评定标准

危险程度	危险值区域	危险程度说明
高	7 <= 漏洞风险值 <= 10	攻击者可以远程执行任意命令或者代码，或进行远程拒绝服务攻击。
中	4 <= 漏洞风险值 < 7	攻击者可以远程创建、修改、删除文件或数据，或对普通服务进行拒绝服务攻击。
低	1 <= 漏洞风险值 < 4	攻击者可以获取某些系统、服务的信息，或读取系统文件和数据。
分值	**评估标准**	
1	可远程获取OS、应用版本信息。	
2	开放了不必要或危险的服务，可远程获取系统敏感信息。	
3	可远程进行受限的文件、数据读取。	
4	可远程进行重要或不受限文件、数据读取。	
5	可远程进行受限文件、数据修改。	
6	可远程进行受限重要文件、数据修改。	
7	可远程进行不受限的重要文件、数据修改，或对普通服务进行拒绝服务攻击。	
8	可远程以普通用户身份执行命令或进行系统、网络级的拒绝服务攻击。	
9	可远程以管理用户身份执行命令（受限、不太容易利用）。	
10	可远程以管理用户身份执行命令（不受限、容易利用）。	

5.2 主机风险等级评定标准

主机风险等级	主机风险值区域
非常危险	7 <= 主机风险值 <= 10
比较危险	5 <= 主机风险值 < 7
比较安全	2 <= 主机风险值 < 5
非常安全	0 <= 主机风险值 < 2

1.将主机的漏洞按照分数的高低排序，依据漏洞的分数将漏洞威胁划分为高、中、低三个类别。
2.按照绿盟科技风险评估模型计算得到风险值。

注：高、中和低漏洞威胁的定义参见《单一漏洞威胁等级评定标准》

5.3 网络风险等级评定标准

网络风险等级	网络风险值区域
非常危险	8 <= 网络风险值 <= 10
比较危险	5 <= 网络风险值 < 8
比较安全	1 <= 网络风险值 < 5
非常安全	0 <= 网络风险值 < 1

网络风险等级是网络中所有主机威胁分值的加权平均和。
1 对网络中的所有主机按照威胁分值进行高低排序，依据主机的威胁分值将主机风险划分为高、中、低三个类别。
2.按照绿盟科技风险评估模型计算得到风险值。

其中：非常危险的主机定义为高风险；比较危险的主机定义为中风险；比较安全和非常安全的主机定义为低风险。

5.4 安全建议

据市场研究公司 Gartner 研究报告称“实施漏洞管理的企业会避免近 90% 的攻击”。可以看出，及时的漏洞修补可以在一定程度上防止病毒、攻击者的威胁。

绿盟科技“远程安全评估系统”建议对存在漏洞的主机参考附件中提出的解决方案进行漏洞修补、安全增强。

建议所有 Windows 系统使用“Windows Update”进行更新。
对于大量终端用户而言，可以采用 WSUS 进行自动补丁更新，也可以采用补丁分发系统及时对终端用户进行补丁更新。
对于存在弱口令的系统，需在加强使用者安全意识的前提下，督促其修改密码，或者使用策略来强制限制密码长度和复杂性。
对于存在弱口令或是空口令的服务，在一些关键服务上，应加强口令强度，同时需使用加密传输方式，对于一些可关闭的服务来说，建议关闭该服务以达到安全目的。
对于UNIX系统订阅厂商的安全公告，与厂商技术人员确认后进行漏洞修补、补丁安装、停止服务等。
由于其他原因不能及时安装补丁的系统，考虑在网络边界、路由器、防火墙上设置严格的访问控制策略，以保证网络的动态安全。
建议网络管理员、系统管理员、安全管理员关注安全信息、安全动态及最新的严重漏洞，攻与防的循环，伴随每个主流操作系统、应用服务的生命周期。
建议采用绿盟科技“远程安全评估系统”安全评估系统定期对网络进行评估，真正做到未雨绸缪。